

24. Webový server - logování, zabezpečení, monitoring

Logování

- Záznam všeho co se děje
- Access Logy - každý požadavek, který na server přišel, obsahuje IP adresu, čas, požadovanou URL a HTTP stavový kód
- Error Logy – jakékoliv selhání, chyby v kódu, chyby v konfiguraci serveru
- Log Management – logrotate, dělit logy do menších souborů (např. po dnech), logy se musí pravidelně komprimovat a mazat staré

Zabezpečení

- SSL/TLS (HTTPS)
 - naprostý základ
 - šifrování komunikace mezi klientem a serverem
 - nginx zde často funguje jako ten, kdo „ukončuje“ šifrování a předává data dál do aplikace
- Firewall a WAF
 - Firewall filtruje porty (pustí jen 80/443)
 - WAF (Web Application Firewall) – chytřejší, dokáže rozpoznat útoky jako SQL Injection přímo v síťovém provozu a zablokovat je
- Ochrana proti DoS/DDoS
 - Nastavení Rate Limitingu v Nginxu
 - Pokud jedna IP adresa pošle např. 100 požadavků za sekundu, server ji automaticky dočasně zablokuje
- Zabezpečení aplikace samotné
 - Autentizace a Autorizace – JWT nebo Cookies pro bezstavovou komunikaci, nebo správu sessions uložených na serveru
 - Hashování hesel – nikdy heslo v plain textu, algoritmy jako Bcrypt + salt
 - Security headers – posílání prohlížeči instrukce (např. *Content-Security-Policy*), pro zakázání spouštění cizích scriptů

Monitoring

- Infrastrukturní metriky – sledování vytížení CPU, RAM a volného místa na disku
- Aplikační metriky – kontrola, zda web vůbec běží, měří se také latence
- Sledování chybovosti – útokud náhle vyskočí počet stavových kódů 500 (nikdy by se nemělo stát), něco je špatně

Nástroje a moderní přístupy

- ELK Stack (Elasticsearch, Logstash, Kibana) – standard pro sběr a vizualizaci milionů logů
- Prometheus a Grafana – nejoblíbenější dvojice pro monitoring metrik a kreslení přehledných grafů
- Alerting – nastavení upozornění, pokud serveru dojde místo na disku, pošle automaticky zprávu na Slack nebo e-mail